LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING

Google Chrome CVE-2026-125350 Actively Exploited XML Use-After-Free Daily Priority

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-11-13
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | Google Chrome CVE-2026-125350 Actively Exploited XML Use-After-Free Daily Priority - CVE / Vulnerability Threat Intelligence Report

Published: 2026-11-13 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Affected Products and Exposure
7. Aviation and Aerospace Sector Impact
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

Google Chrome CVE-2026-125350 Actively Exploited XML Use-After-Free Daily Priority

1. Executive Summary

CVE-2026-125350 is a high-severity use-after-free vulnerability in the XML component of Google Chrome before version 157.0.8103.50. NVD states that a crafted HTML page can execute arbitrary code inside the sandbox. Google released the referenced Stable-channel update on 2026-11-09; CISA added the CVE to KEV on 2026-11-10, establishing active-exploitation prioritization.

Prioritize rapid managed-browser patching and relaunch verification, especially for privileged users, security administrators, finance, engineering, and aviation/aerospace operational-support personnel. The reviewed sources do not identify the threat actor, campaign, victim set, exploit delivery infrastructure, or a universal sandbox escape. Do not infer these claims from KEV listing alone.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-125350
Product / component	Google Chrome XML component; Chromium-derived browsers require vendor-specific validation
Weakness	Use-after-free
Severity	High (Chromium severity, per NVD)
Affected version	Chrome prior to 157.0.8103.50
Fixed version	157.0.8103.50 or later for the cited desktop release stream
Exploitation status	CISA KEV-listed on 2026-11-10; Google acknowledges an in-the-wild exploit

3. Source Review & Confidence

Source	Contribution	Confidence
Google Chrome Releases	Primary release and patch context	High
NVD CVE record	Canonical CVE description and version boundary	High
CISA KEV Catalog	Active-exploitation prioritization	High
Chromium issue reference	Upstream issue tracking reference, access may be restricted	Medium
Malwarebytes / The Hacker News	Supporting reporting on the update and exploitation statement	Medium

The existence, affected-version boundary, and active-exploitation priority are corroborated by Google/NVD/CISA records. Public technical details remain limited; detection should focus on patch compliance and web-delivery telemetry rather than claims about a particular exploit artifact.

4. Vulnerability Details

NVD describes a use-after-free in Chrome's XML component before 157.0.8103.50. A remote attacker can use a crafted HTML page to execute arbitrary code inside the sandbox. The source language is intentionally scoped: it does not establish sandbox escape, persistence, or post-exploitation behavior. Other Chromium-derived products should be assessed against their own vendor advisories rather than assumed vulnerable or fixed on Google's schedule.

5. Attack Scenarios

Scenario	Preconditions	Defender focus
Malicious or compromised webpage	User browses to attacker-controlled content on a vulnerable Chrome build	Patch/relaunch compliance, DNS/proxy telemetry, endpoint triage
Targeted social engineering	User opens a link delivered through email, chat, or collaboration platform	URL filtering, user reporting, browser-version enforcement
Privileged workstation targeting	Administrator or engineering user browses on an unpatched device	Expedite patching and separate privileged workflows

6. Affected Products and Exposure

Exposure pattern	Why it matters	Priority
Managed Chrome below 157.0.8103.50	Known exploited browser exposure	Critical
Browser updated but not relaunched	Security fix may not be active in the running process	High
Unmanaged/BYOD browser	Patch state may be unknown	High
Chromium-derived browser	Scope/fixed version must be confirmed with its vendor	Verify

7. Aviation and Aerospace Sector Impact

Segment	Operational relevance	Likely exposure path	Defender action
Airline/airport business and operations support	Browser-based scheduling, crew, supplier and support portals create routine web exposure	Phishing links, compromised websites, unmanaged kiosks	Enforce rapid browser updates and restrict admin browsing
Aerospace engineering and MRO	High-value design and maintenance users use web collaboration and vendor portals	Targeted delivery to privileged engineering users	Patch managed endpoints, segment engineering assets, monitor proxy events
Ground/space mission support	Web consoles and documentation portals may be accessed from privileged endpoints	Web-delivered initial access against operators	Use hardened admin workstations and verify restart compliance

This sector analysis is defensive context, not evidence of aviation or aerospace targeting by the CVE's exploitation activity.

8. Mitigation and Workarounds

1. Force-update Chrome desktop installations to 157.0.8103.50 or later and require browser restart.

2. Obtain a version-compliance report covering managed workstations, VDI, kiosks, jump hosts, and privileged-admin endpoints.
3. Confirm patch status for Microsoft Edge, Opera, and other Chromium-derived browsers with the relevant vendor; do not assume Google fixes apply directly.
4. Prioritize users who access identity, finance, engineering, cloud-administration, airline/airport operations, or aerospace supplier systems.
5. Preserve proxy, DNS, EDR, and browser-extension telemetry for endpoints with suspicious web activity before reimaging.

9. Detection Engineering

Signal	Telemetry	Analytic goal
Chrome version below fixed baseline	EDR, MDM, software inventory	Find patch/restart exceptions
Browser contacting newly observed suspicious URLs	Proxy, DNS, secure web gateway	Prioritize possible web-delivery events
Unusual child process spawned by browser	EDR process telemetry	Identify suspicious post-browser execution for triage

```
DeviceTvmSoftwareInventory
| where SoftwareName has "Google Chrome"
| project DeviceName, SoftwareName, SoftwareVersion
| order by DeviceName asc
```

10. Threat Hunting

Hypothesis: a vulnerable browser visited a suspicious external site and was followed by unexpected browser child-process or network activity.

```
DeviceProcessEvents
| where Timestamp > ago(30d)
| where InitiatingProcessFileName in~ ("chrome.exe", "google-chrome", "chrome")
| where FileName !in~ ("chrome.exe", "crashpad_handler.exe")
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine,
InitiatingProcessCommandLine
| order by Timestamp desc
```

Investigate hits using browser version, user context, URL/DNS records, signed-binary reputation, and known maintenance activity. Browser child processes are not by themselves proof of CVE exploitation.

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / rationale
T1189	Drive-by Compromise	Analytic mapping because a crafted webpage is the stated delivery condition; not incident proof

12. Validation / Lab Testing

No exploit was executed. Source validation covered the Google release reference, NVD description, and CISA KEV entry. Local validation should verify deployment policy, installed version, process restart state, and endpoint telemetry in an authorized environment.

13. Recommended Actions Summary

Priority	Owner	Action

Critical	Endpoint engineering	Force-update and relaunch Chrome fleet-wide
High	SOC	Hunt browser-child-process and suspicious-web events on unpatched devices
High	IT/asset management	Resolve unmanaged and stale-version endpoints
High	Aviation/aerospace operations security	Prioritize privileged operational-support and engineering workstations

14. References

- https://chromereleases.googleblog.com/2026/11/stable-channel-update-for-desktop_018223192.html
- https://nvd.nist.gov/vuln/detail/CVE-2026-125350
- https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-125350
- https://issues.chromium.org/issues/582442907
- https://www.malwarebytes.com/blog/bugs/2026/11/update-chrome-now-to-fix-a-flaw-attackers-are-exploiting
- https://thehackernews.com/2026/11/google-issues-chrome-security-update.html